

НОВОСТИ

- [Making frontier cybersecurity capabilities available to defenders \ Anthropic](#)
- **Claude Code Security**, a new capability built into Claude Code on the web, is now available in a limited research preview. It scans codebases for security vulnerabilities and suggests targeted software patches for human review, allowing teams to find and fix security issues that traditional methods often miss.
- <https://www.nytimes.com/2026/02/24/us/politics/pentagon-anthropic.html>
- The Pentagon delivered an ultimatum to Anthropic, the only artificial intelligence company currently operating on classified military systems, ordering the firm to bend to its demands by Friday. If the firm fails to agree by 5:01 p.m. on Friday, Defense Secretary Pete Hegseth said the Trump administration would invoke the Defense Production Act, compelling the use of its model by the military and labeling the company a supply chain risk, according to a senior Pentagon official. That step would put Anthropic's government contracts at risk.
- <https://securityonionsolutions.com/software/>
- **Security Onion** is a free and open platform built by defenders for defenders. It includes network visibility, host visibility, intrusion detection honeypots, log management, and case management. For network visibility, we offer signature based detection via Suricata, rich protocol metadata and file extraction using your choice of either Zeek or Suricata, full packet capture via Suricata PCAP, and file analysis via Strelka.

Формальные модели безопасности Модели KVM & CW

Промыслов Виталий Георгиевич
vitaly.promyslov@gmail.com

Литература

Основная:

- Лекции

Дополнительная:

- D. Clark and D. Wilson, “A Comparison of Commercial and Military Security Policies,” Proceedings of the 1987 IEEE Symposium on Security and Privacy, pp. 184–194 (Apr. 1987).
- Brewer, D.F.C.; Nash, M.J. (1989). ["The Chinese Wall security policy"](#) (PDF). *Proceedings. 1989 IEEE Symposium on Security and Privacy*. IEEE. pp. 206–214

Модель Кларка-Вилсона (D. Clark и D. Wilson) и политика обеспечения целостности

Целостность. Свойство системы, отражающее логическую корректность и надежность системы, логическую полноту аппаратного и программного обеспечений, которые реализуют защитные механизмы, а также постоянство структуры и содержания хранимых данных [IEC/TS 62443-1-1].

Целостность ПО и данных. Состояние ПО и данных, характеризующееся отсутствием изменений преднамеренного или случайного характера [ГОСТ Р 8.654-2015].

- **Согласованность (consistence) транзакций**
- **Проверка и удостоверение транзакции**

Формальное определение элементов КВМ

- U — множество пользователей (субъектов);
- D -множество всех данных в цифровой системе. Для ОС это могут быть каталоги, файлы, области памяти и т.д.
- $U \cap D = \emptyset$.

Данные в KBM

- $CDI = \{cdi\}$ (constrained data items) - множество *ограниченных данных*. Данные которые обладают и должны в далее обладать целостностью.
- $UDI = \{udi\}$ (unconstrained data items) - множество *неограниченных данных*. Данные которые не обладают целостностью.
- $D = CDI \cup UDI$
- $CDI \cap UDI = \emptyset$.

Процедуры KBM

- $IVP: CDI \rightarrow \{true, false\}$ (integrity verification procedure) - процедуры проверки целостности, проверяющие, что $\forall cdi \in CDI$ соответствуют ограничениям целостности (по крайней мере вовремя, когда IVP запущены). В этом случае говорят, что система находится в безопасном состоянии.
- $TP: CDI \rightarrow CDI$, (transformation procedure) - процедуры трансформации, которые изменяют состояние данных в системе с одного безопасного состояния на другое и которые реализуют правильные транзакции.

Правила KBM-1

- Правило 1 (CR1). В системе должны иметься IVP, утверждающие целостность любого CDI.
- Правило 2 (CR2). Применение некоторого набора процедур из *TP* к ассоциированному с ним набору данных из *CDI* должно сохранять целостность этого набора CDI.

Правила KBM-2

- Правило принуждения 1 (ER1): система должна гарантировать, что только TP , сертифицированные для работы на CDI , управляют этим CDI . В частности, правило говорит, что если $t \in TP$ работает с $cdi \in CDI$ то $(t, cdi) \in C$.
- Правило принуждения 2 (ER2): система должна связать пользователя с каждой процедурой TP и установить CDI . TP может получить доступ к этим CDI от имени соответствующего пользователя. $A: U \rightarrow \{(u \in U, \{t\} \subseteq TP, \{cdi\} \subseteq CDI)\}$

Правила KBM-3

- Правило сертификации 3 (CR3): Разрешенные отношения *A* должны соответствовать требованиям принципа разделения обязанностей.
- Правило принуждения 3 (ER3): система должна аутентифицировать каждого пользователя, пытающегося выполнить *TP*.

Правила KBM-3

- Правило сертификации 4 (CR4): все *TP* должны добавлять в лог достаточно информации для аудита операция в *CDI*, информация в лог может только добавляться.
- Правило сертификации 5 (CR5): Любой *TP*, принимающий в качестве входных данных *UDI*, может выполнять только действительные преобразования или отсутствие преобразований для всех возможных значений *UDI*. Преобразование либо отвергает *UDI*, либо преобразует его в *CDI*.

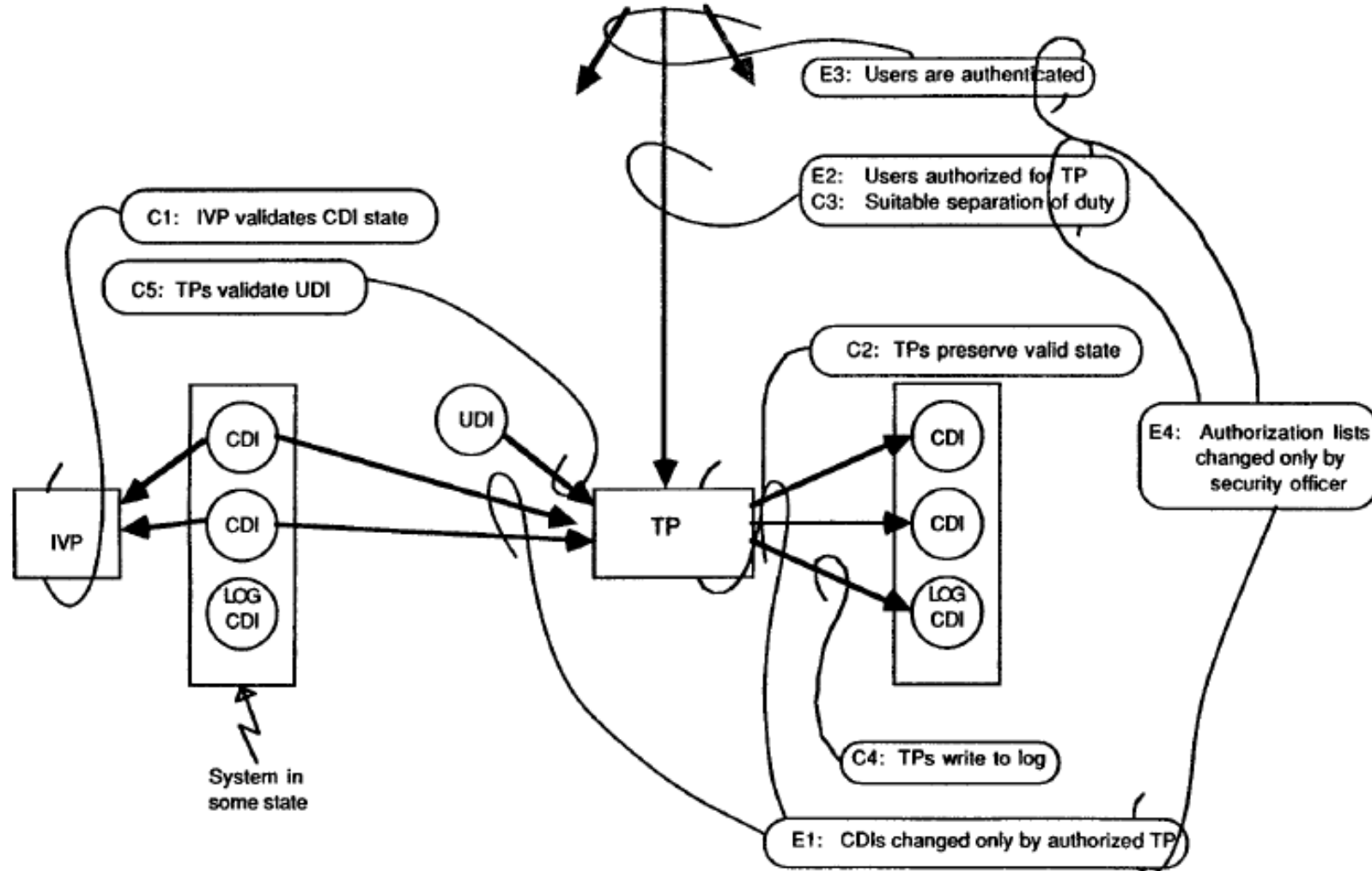
Правила KBM-3

- Правило принуждения 4 (ER4): Только авторизованное лицо для каждой процедуры из TP может изменить набор атрибутов связанных с этим TP . Любой другой субъект в системе не может менять атрибуты TP .

Заключение

- КВМ основан на методах используемых большинством коммерческих организаций которые работают с данными
- КВМ разделило понятие сертификации (одобрение) от принуждения, и каждое из них имеет свой собственный набор правил
- Целостность данных обеспечивается тем, что каждое действие с данными сертифицировано (одобрено) доверенным субъектом, **однако сами данные не проверяются**

Структура правил КВМ



Модель безопасности Китайская стена (Chinese Wall)

- Модель китайской стены (CW-Chinese Wall) представляет собой модель политики безопасности, которая в равной степени относится к конфиденциальности и целостность.

Элементы модели CW-1

- **Определение:** C – множество компаний;
- **Определение:** O – множество объектов данных о различных компаниях. Объектами данных являются записи информации, каждая запись связана с определенной компанией клиентом;
- **Определение:** S – множество субъектов.
- **Определение.** Отношение (company dataset - CD) задает на всем множестве данных множество данных, относящиеся к одной компании, $CD: O \rightarrow O$
- **Определение.** Отношение COI задает соответствие между множеством C и классами конфликта интересов (conflict of interest),

Элементы модели CW-2

- **Определение.** Обозначим $PR(S)$ — множество объектов, прочитанных субъектом S .
- **Определение.** Простое условие безопасности (ss), в модели CW : Субъект S может читать O , тогда и только тогда если верно хотя бы одно из условий:
 1. Существует объект O' такой, что S имеет доступ к O' и $CD(O') = CD(O)$, т.е. субъект ранее имел доступ к объекту принадлежащему тому же CD .
 2. Для всех объектов $O' \in PR(S) \Rightarrow COI(O') \neq COI(O)$. Все объекты к которым ранее имел доступ субъект принадлежали к другим классам конфликта интересов. Заметим, что первоначально $PR(S) = \emptyset$, и предполагается, что первоначальный любой запрос на чтение всегда удовлетворён.

Элементы модели CW-3

- **Определение.**
- $SDI = \{Sdi\} \subseteq O$ (sanitized data item) - множество *безопасных данных*. Данные которые не обладают конфиденциальностью и их целостность не является задачей безопасности.
- $UDI = \{udi\} \subseteq O$ (unsanitized data items) - множество *критичных данных*. Данные которые обладают конфиденциальностью и их целостность является задачей безопасности.
- $O = SDI \cup UDI$
- $SDI \cap UDI = \emptyset$.
- **Добавление к предыдущему слайду:**
- Условие 3: Объект $\{o \in O\} \subseteq SDI$, т.е. является безопасным.

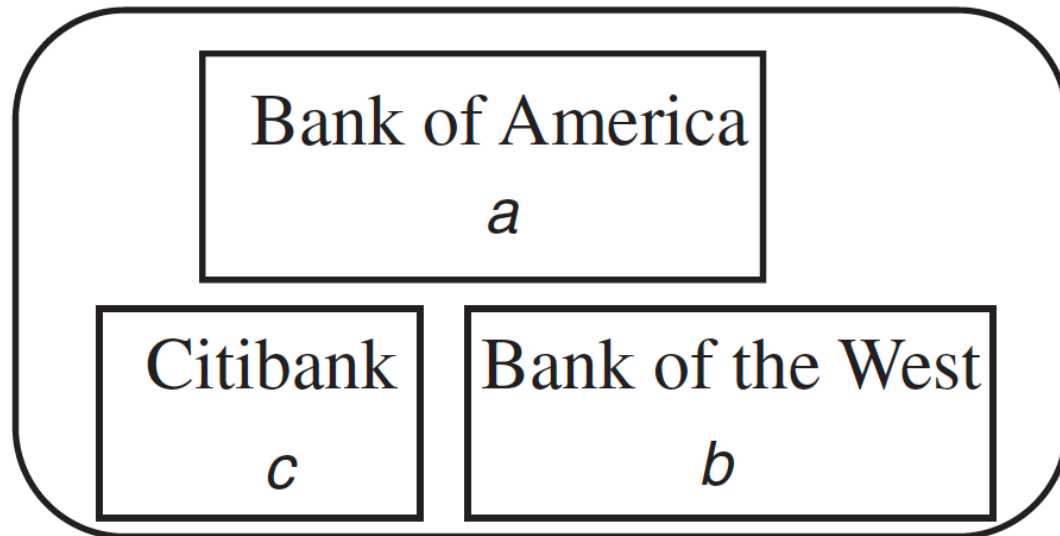
Элементы модели CW-4

- **Определение.** Строгое свойство безопасности модели CW *. Субъект S может писать объекту O тогда и только тогда, когда выполняются следующие два условия:
 1. Условие безопасности CW-simple позволяет S читать O .
 2. Для всех критичных объектов $O' \in USDI$, S может читать $O' \Rightarrow CD(O') = CD(O)$.

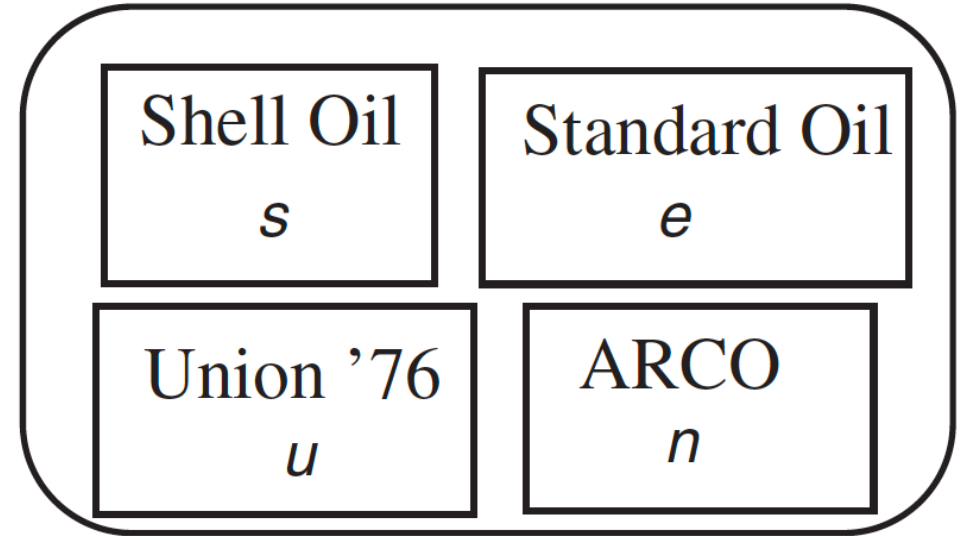
.

Пример структуры база данных моделей CW

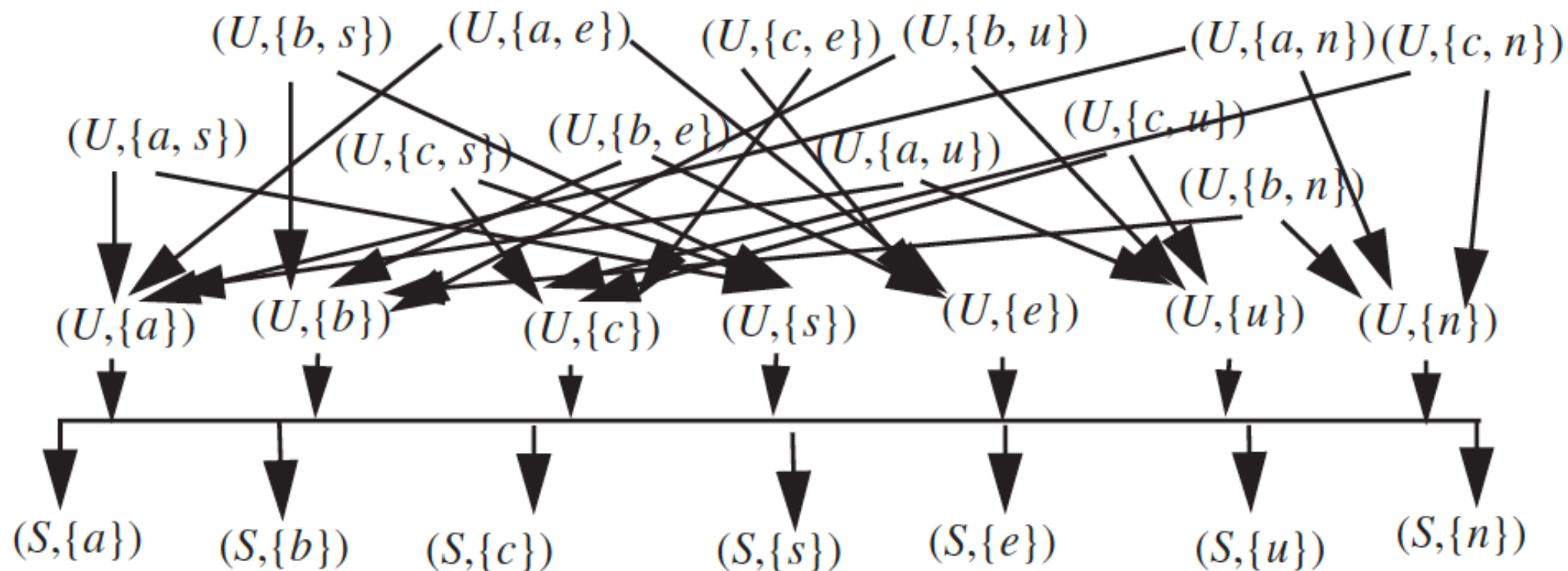
Bank COI Class



Gasoline Company COI Class



Сравнение модели Белл-Лападула и модели безопасности Китайская стена



Ограничения выражении модели CW моделью Белла-ЛаПадулы

- Во-первых, модель Белла-ЛаПадулы не может фиксировать изменения с течением времени, так как у нее нет памяти.
- Во-вторых, субъекты в модели CW могут выбирать, к каким CD обращаться; другими словами, изначально субъект имеет свободный доступ ко всем объектам. В модели Белл-ЛаПадула, с самого начала ограничивается набор объектов, к которым может получить доступ субъект. Этот набор не может измениться если доверенный субъект, (например, офицер безопасности системы) не изменит допуск субъекта или классификации объектов.